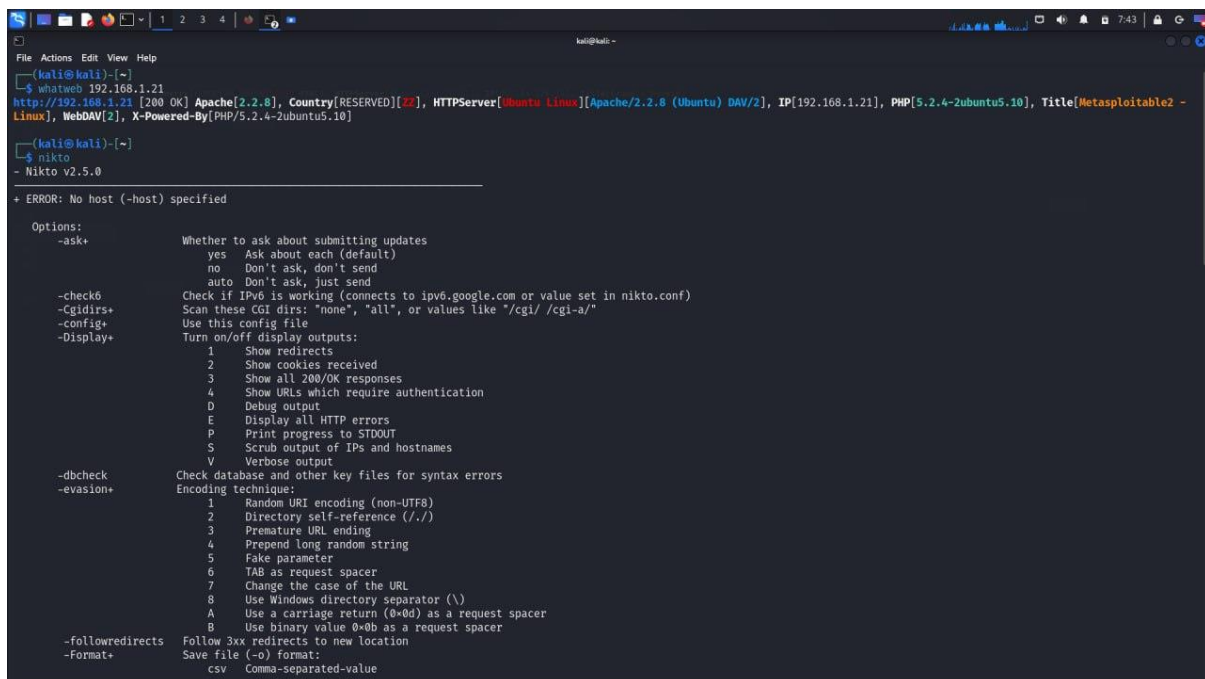


Information Gathering

1)Active information gathering – whatweb

The web command in Kali Linux is part of the Kali tools suite designed for web application penetration testing. It typically serves as a shorthand or entry point to various web-related tools and services, such as starting a web server or running web vulnerability scanning tools like Nikto, Burp Suite, or OWASP ZAP. It helps streamline the process of assessing and securing web applications.



```
(kali@kali)~$ whatweb 192.168.1.21
http://192.168.1.21 [200 OK] Apache[2.2.8], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.1.21], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]

(kali@kali)~$ nikto
- Nikto v2.5.0

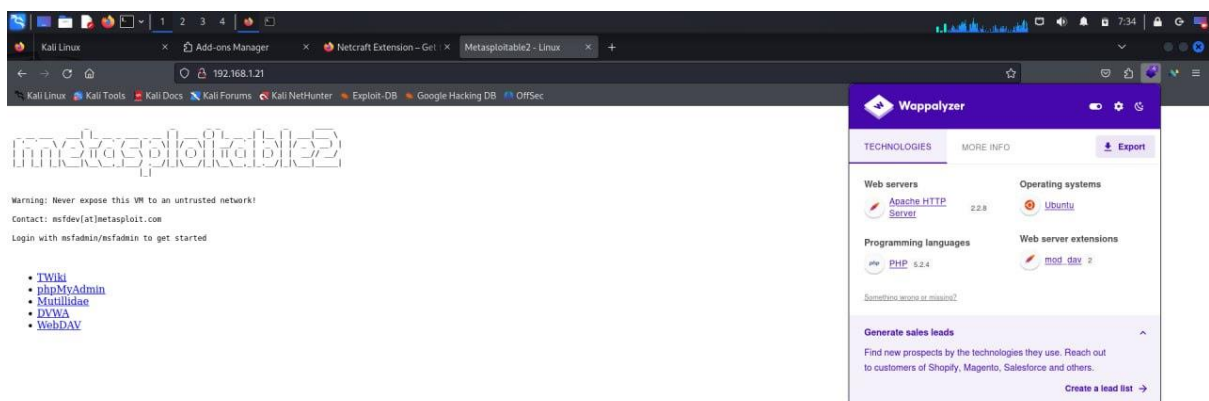
+ ERROR: No host (-host) specified

Options:
-ask+          Whether to ask about submitting updates
                yes      Ask about each (default)
                no      Don't ask, don't send
                auto     Don't ask, just send
-check6       Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
-cgidirs+     Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
-config+      Use this config file
-Display+     Turn on/off display outputs:
                1      Show redirects
                2      Show cookies received
                3      Show all 200/OK responses
                4      Show URLs which require authentication
                D      Debug output
                E      Display all HTTP errors
                P      Print progress to STDOUT
                S      Scrub output of IPs and hostnames
                V      Verbose output
-dbcheck      Check database and other key files for syntax errors
-evasion+     Encoding techniques:
                1      Random URI encoding (non-UTF8)
                2      Directory self-reference (../)
                3      Premature URL ending
                4      Prepend long random string
                5      Fake parameter
                6      TAB as request spacer
                7      Change the case of the URL
                8      Use Windows directory separator (\)
                A      Use a carriage return (0x0d) as a request spacer
                B      Use binary value 0x0b as a request spacer
-followredirects Follow 3xx redirects to new location
-format+      Save file (-o) format:
                csv     Comma-separated-value
```

2)Passive information gathering

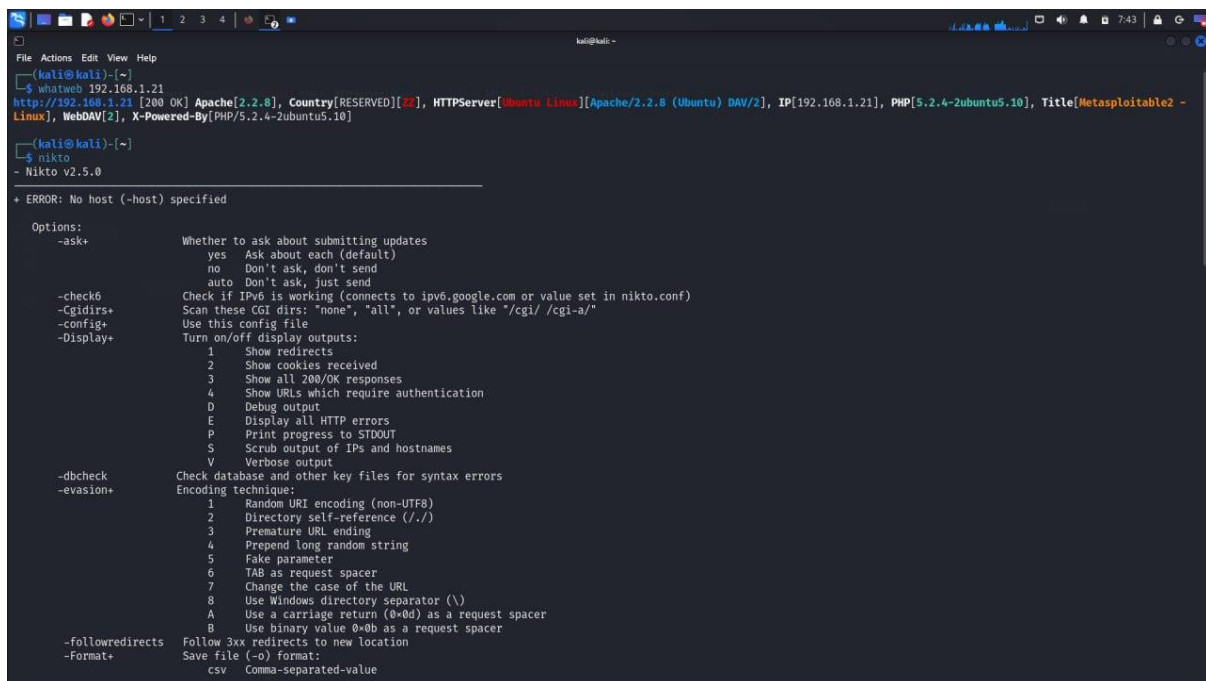
Wappalyzer

Wappalyzer is a web technology profiler that identifies the software and technologies used by websites. It can detect web servers, content management systems (CMS), programming languages, analytics tools, and various frameworks. It's available as a browser extension or as an API, helping developers, marketers, and security professionals understand the tech stack of a website.



3) nikto

The nikto command in Kali Linux is a web server scanner used to identify security vulnerabilities in web applications. It performs comprehensive checks for outdated software, security misconfigurations, potential exploits, and common issues like default files or insecure server settings. Nikto is useful for quickly assessing the security of web servers and identifying potential risks.



```
(kali@kali)-[~]
└─$ whatweb 192.168.1.21
http://192.168.1.21 [200 OK] Apache[2.2.8], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.1.21], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]

(kali@kali)-[~]
└─$ nikto
- Nikto v2.5.0

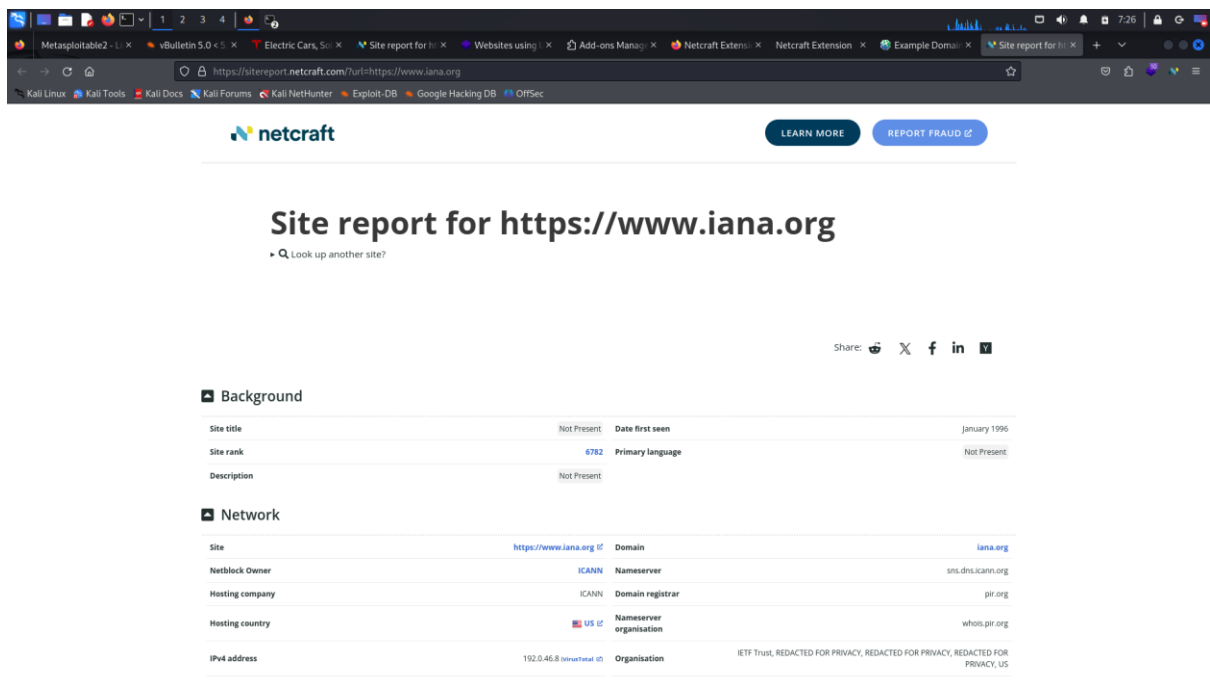
+ ERROR: No host (-host) specified

Options:
-ask+          Whether to ask about submitting updates
                yes    Ask about each (default)
                no     Don't ask, don't send
                auto   Don't ask, just send
-check6        Check if IPv6 is working (connects to ipv6.google.com or value set in nikto.conf)
-Cgidirs+      Scan these CGI dirs: "none", "all", or values like "/cgi/ /cgi-a/"
-config+       Use this config file
-Display+      Turn on/off display outputs:
                1      Show redirects
                2      Show cookies received
                3      Show all 200/OK responses
                4      Show URLs which require authentication
                D      Debug output
                E      Display all HTTP errors
                P      Print progress to STDOUT
                S      Scrub output of IPs and hostnames
                V      Verbose output
-dbcheck       Check database and other key files for syntax errors
-evasion+      Encoding technique:
                1      Random URI encoding (non-UTF8)
                2      Directory self-reference (../)
                3      Premature URL ending
                4      Prepend long random string
                5      Fake parameter
                6      TAB as request spacer
                7      Change the case of the URL
                8      Use Windows directory separator (\)
                A      Use a carriage return (0x0d) as a request spacer
                B      Use binary value 0x0b as a request spacer
-followredirects Follow 3xx redirects to new location
-Format+       Save file (-o) format:
                csv    Comma-separated-value
```

```
File Actions Edit View Help
-mutate+ Guess additional file names:
-mutate-options Provide information for mutates
-nointeractive Disables interactive features
-nolookup Disables DNS lookups
-nossl Disables the use of SSL
-noslash Strip trailing slash from URL (e.g., '/admin/' to '/admin')
-no404 Disables nikto attempting to guess a 404 page
-Option Over-ride an option in nikto.conf, can be issued multiple times
-output+ Write output to this file ('.' for auto-name)
-Pause+ Pause between tests (seconds)
-Plugins+ List of plugins to run (default: ALL)
-port+ Port to use (default 80)
-RScert+ Client certificate file
-root+ Prepend root value to all requests, format is /directory
-Save Save positive responses to this directory ('.' for auto-name)
-ssl Force ssl mode on port
-Tuning+ Scan tuning:
      1 Interesting File / Seen in logs
      2 Misconfiguration / Default File
      3 Information Disclosure
      4 Injection (XSS/Script/HTML)
      5 Remote File Retrieval - Inside Web Root
      6 Denial of Service
      7 Remote File Retrieval - Server Wide
      8 Command Execution / Remote Shell
      9 SQL Injection
      0 File Upload
      a Authentication Bypass
      b Software Identification
      c Remote Source Inclusion
      d Webservice
      e Administrative Console
      x Reverse Tuning Options (i.e., include all except specified)
-timeout+ Timeout for requests (default 10 seconds)
-Userdb+ Load only user databases, not the standard databases
      all Disable standard dbs and load only user dbs
      tests Disable only db_tests and load udb_tests
-useragent Over-rides the default useragent
-until Run until the specified time or duration
-url+ Target host/URL (alias of -host)
-usecookies Use cookies from responses in future requests
-useproxy Use the proxy defined in nikto.conf, or argument http://server:port
-Version Print plugin and database versions
-vhost+ Virtual host (for Host header)
```

4) Netcraft

The Netcraft extension is a browser tool that provides detailed information about websites, such as their hosting provider, SSL certificates, technologies used, and historical data like uptime and security incidents. It helps users identify potential threats, phishing sites, and fraudulent activities by analyzing the underlying infrastructure of websites. This extension is valuable for cybersecurity professionals and researchers.



The screenshot shows the Netcraft website interface in a browser. The address bar displays the URL <https://sitereport.netcraft.com?url=https://www.iana.org>. The page features the Netcraft logo and navigation buttons for "LEARN MORE" and "REPORT FRAUD". The main heading is "Site report for https://www.iana.org", with a link to "Look up another site?". Social sharing options for Twitter, Facebook, LinkedIn, and Print are available. The report is divided into two sections: "Background" and "Network".

Background

Site title	Not Present	Date first seen	January 1996
Site rank	6782	Primary language	Not Present
Description	Not Present		

Network

Site	https://www.iana.org	Domain	iana.org
Netblock Owner	ICANN	Nameserver	sns.dns.icann.org
Hosting company	ICANN	Domain registrar	pir.org
Hosting country	US	Nameserver organisation	whois.pir.org
IPv4 address	192.0.46.8 (Internet)	Organisation	IETF Trust, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, REDACTED FOR PRIVACY, US

netcraft

LEARN MOREREPORT FRAUD

IPv4 autonomous systemsAS16876DNS adminnoc@dns.icann.org

IPv6 address2620:0:2830:200:0:b:8Top Level DomainOrganization entities (.org)

IPv6 autonomous systemsAS16876DNS Security ExtensionsEnabled

Reverse DNS46-8.dn.icann.org

IP delegation

IPv4 address (192.0.46.8)

IP range	Country	Name	Description
::ffff:0:0-0:0/96	United States	IANA-IPv4-MAPPED-ADDRESS	Internet Assigned Numbers Authority
192.0.0.0-192.255.255.255	United States	NET192	Various Registries (Maintained by ARIN)
192.0.32.0-192.0.47.255	United States	ICANN	ICANN
192.0.46.8	United States	ICANN	ICANN

IPv6 address (2620:0:2830:200:0:b:8)

IP range	Country	Name	Description
:::0	N/A	ROOT	Root inetnum object
2620:::23	United States	ARIN-V6-ENDUSER-BLOCK	American Registry for Internet Numbers
2620:0:2830:::48	United States	ICANN-DC-IPv6	ICANN
2620:0:2830:200:0:b:8	United States	ICANN-DC-IPv6	ICANN

IP Geolocation

We use multilateration to independently determine the location of a server. [Read more.](#)

netcraft

LEARN MOREREPORT FRAUD

IP Geolocation

We use multilateration to independently determine the location of a server. [Read more.](#)

Legend:

Advertised country

Multilaterated location

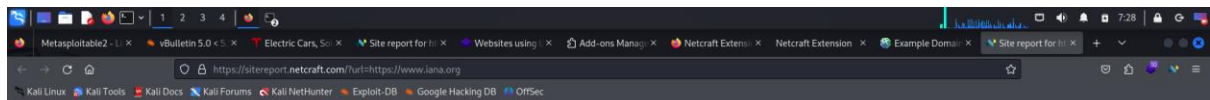
Leaflet | © OpenStreetMap contributors

SSL/TLS

Assurance

Organisation validationPerfect Forward Secrecy

Common name*.iana.orgSupported TLS ExtensionsRFC8446 key share, RFC8446 supported versions



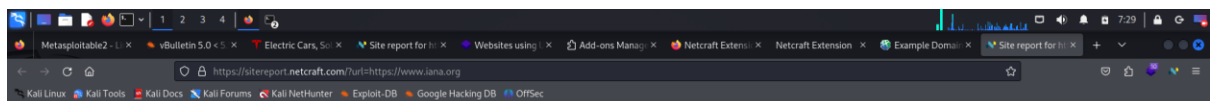
[LEARN MORE](#)

[REPORT FRAUD](#)

Leaflet | © OpenStreetMap contributors

SSL/TLS

Assurance	Organisation validation	Perfect Forward Secrecy	Yes
Common name	*.iana.org	Supported TLS Extensions	RFC8446 12 key share, RFC8446 12 supported versions
Organisation	Internet Corporation For Assigned Names and Numbers	Application-Layer Protocol Negotiation	Not Present
State	California	Next Protocol Negotiation	Not Present
Country	US	Issuing organisation	Sectigo Limited
Organisational unit	Not Present	Issuer common name	Sectigo RSA Organization Validation Secure Server CA
Subject Alternative Name	*.iana.org, iana.org	Issuer unit	Not Present
Validity period	From Dec 5 2023 to Jan 9 2025 (12 months, 4 weeks, 1 day)	Issuer location	Salford
Matches hostname	Yes	Issuer country	GB
Server	Apache	Issuer state	Greater Manchester
Public key algorithm	rsaEncryption	Certificate Revocation Lists	http://crl.sectigo.com/SectigoRSAOrganizationValidationSecureServerCA.crl
Protocol version	TLSv1.3	Certificate Hash	sbj5N1TWPh0VC24WeBhuj+Y0G0
Public key length	4096	Public Key Hash	d56f85824b6ed2ab1569040c20b574515d9a0ab415ca253b42bc915a11de18d
Certificate check		OCSP servers	http://ocsp.sectigo.com
Signature algorithm	sha256WithRSASignature	OCSP stapling response	No response received
Serial number	0x1f4b4305931a2432c0de888b3d1d675		
Cipher	TLS_AES_256_GCM_SHA384		
Version number	0x02		





LEARN MORE

REPORT FRAUD

Certificate Transparency

Signed Certificate Timestamps (SCTs)

Source	Log	Timestamp	Signature Verification
Certificate	Unknown zxPw713uRk/zh1vZs5688puzBqpf+ysA6Jb68786up=	2023-12-05 22:21:03	Unknown
Certificate	Unknown au9KSCXva2bfj1182c399c04501y1e6y2EwCk8=c=	2023-12-05 22:21:03	Unknown
Certificate	Unknown Tm6J31ys8P9W42x032956x3u414bJhAs7pkxMa8d8=	2023-12-05 22:21:03	Unknown

SSLv3/POODLE

This site does not support the SSL version 3 protocol.

[More information about SSL version 3 and the POODLE vulnerability.](#)

Heartbleed

The site did not offer the Heartbeat TLS extension prior to the Heartbleed disclosure, and so was not exploitable.

This test does not exploit the Heartbleed vulnerability but uses information from conventional HTTPS requests. [More information about Heartbleed detection.](#)

SSL Certificate Chain

Sender Policy Framework

A host's Sender Policy Framework (SPF) describes who can send mail on its behalf. This is done by publishing an SPF record containing a series of [rules](#). Each rule consists of a qualifier followed by a specification of which domains to apply this qualifier to. For more information please see [open-spf.org](#).

Warning: it appears that this host does not have an SPF record. There may be an SPF record on [iana.org](#). Check the [site report](#).

Setting up an SPF record helps prevent the delivery of forged emails from your domain. Please note that an SPF record will only protect the domain it is added to and not any mail